SignSecure TrustFlow — Analyse concurrentielle et contexte béninois

Sep 28, 2026 · @Durabilis & co

Synthèse

SignSecure TrustFlow occupe un créneau libre : aucune solution étudiée ne relie signature électronique, vérification publique et preuve sur document papier. Pour le défendre, il faut corriger 3 écarts de fonctionnalité et 4 failles de sécurité relevées dans le code.

Marché. DocuSign, Yousign, Documenso et DocuSeal ne traitent que le numérique. Au Bénin, l'ANIP (QR vérifiables) et la gestion électronique des courriers servent l'administration, pas les contrats privés. La région avance « l'État d'abord » (Sygidan-Cti en Côte d'Ivoire, FasoSign au Burkina Faso).

Cadre béninois. Le Code du numérique admet la preuve électronique (art. 266, 268), mais ne présume fiable que la signature qualifiée (art. 284–285). Se présenter comme prestataire de confiance sans l'être est un délit (art. 324). Biométrie, numéro national d'identification et hébergement hors Bénin exigent une autorisation APDP (art. 407). Sur le terrain, le mobile domine : 10,6 millions d'abonnements internet mobile, internet fixe sous 1 %.

Écarts de fonctionnalité.

- Pas d'OTP par SMS (email seulement).
- Comparaison des photos Trace simulée (score calculé sur la taille des fichiers).
- Verdict binaire « correspond / diverge » renvoyé pour Trace, contraire à CLAUDE.md.

Failles de sécurité.

- PDF final non scellé : son intégrité ne se contrôle qu'en passant par SignSecure.
- Lien et OTP de signature dans la même boîte mail : une boîte piratée suffit pour signer.
- Photos Trace importables depuis la galerie, sans empreinte calculée à l'envoi.
- Aucune expiration de session sur inactivité.

PKI. Indispensable seulement pour la signature qualifiée, exclue du MVP. Un cachet de plateforme auto-signé, étiqueté « démonstration, non qualifié », est faisable et reconnu comme recevable (art. 293).

Décisions en attente.

Décision	Options	Recommandation
Comparaison des photos Trace	A : côte à côte + jugement humain enregistré ; B : OCR	A pour le MVP ; B nécessite ta validation (CLAUDE.md)
Scellement du PDF	Rien ; code + QR + début du hash imprimés ; cachet PAdES auto-signé	Imprimer d'abord, cachet ensuite si le temps le permet
Horodatage par un tiers (RFC 3161)	Oui / non	Optionnel : seul le hash sortirait, mais c'est un service externe

Objectif et méthode

Aucune solution étudiée ne couvre à la fois la signature (Sign), la vérification publique (Verify) et la preuve sur document papier (Trace). C'est l'angle de SignSecure TrustFlow. Cette analyse identifie ce que font les solutions existantes, ce qui est reproductible dans un MVP de soutenance, et ce que le contexte béninois change.

- **Périmètre** : signature électronique, vérification de documents par code/QR, traçabilité de documents physiques.
- **Critères** : parcours signataire, contrôle d'identité, preuve produite, vérification par un tiers, prise en charge du papier, adaptation au contexte local, prix.
- **Limites** : sources publiques (sites éditeurs, textes de loi), aucun test d'offre payante. Les prix et fonctionnalités évoluent ; vérifier avant la soutenance.

Solutions internationales de signature électronique

Les leaders convergent sur le même socle : lien par email, OTP SMS/email, journal d'audit et « dossier de preuve » joint au PDF signé. SignSecure reproduit déjà ce socle ; aucun ne traite le document papier.

Solution	Modèle	Contrôle du signataire	Preuve produite	Vérification par un tiers
DocuSign	SaaS payant, leader mondial	Email + OTP SMS/appel, questions KBA, vérification de pièce d'identité, eID, signature qualifiée UE	Certificate of Completion + historique de l'enveloppe (chaque authentification y est consignée)	Via l'Envelope ID, par l'administrateur du compte
Yousign	SaaS français, 3 niveaux eIDAS (simple, avancée, qualifiée)	Sans code, code SMS ou code email	Audit trail par signataire : identités, IP, mode d'authentification, contexte, date de consentement, hash du PDF signé	Par recalcul du hash du PDF
Documenso	Open source (AGPL), auto-hébergeable	Rôles signataire / approbateur, lien par email	Certificat de signature PDF, audit log	Pas de page publique ; demandée par la communauté
DocuSeal	Open source (AGPLv3) + options Pro	Email ; vérification SMS en option payante	Signature PDF automatique	« PDF signature verification » intégrée

Points à retenir pour SignSecure :

- **Le dossier de preuve est le vrai produit.** Yousign le résume en 5 blocs : expéditeur, signataire, authentification, contexte, empreinte du document. Le rapport de preuve SignSecure doit contenir au minimum ces 5 blocs.
- **Le consentement est daté séparément de la signature.** Yousign enregistre « date of consent » et « date of signature validation ». SignSecure a déjà la case de confirmation puis l'OTP : il suffit de journaliser les deux horodatages.
- **La vérification publique est un manque chez les open source.** C'est un angle différenciant pour Verify.
- **Biométrie et pièce d'identité (DocuSign ID Verification)** : hors périmètre MVP par décision actée. À citer comme évolution possible, pas à reproduire.

Vérification par QR et traçabilité du papier

La vérification par QR est déjà familière au Bénin, mais uniquement pour des documents émis par l'État. La traçabilité du papier existe sous forme de gestion du courrier, orientée circulation interne, pas preuve en cas de litige. Aucune offre ne vise un document privé signé à la main.

Solution	Ce qu'elle fait	Limite pour notre cas
Certificat d'Identification Personnelle (ANIP)	Carte avec 2 QR codes pour contrôler l'authenticité, via l'app ANIP BJ ou service-public.bj ; 1 000 F CFA, délivré dès paiement	Réservé aux actes émis par l'État
Documents e-services (ex. impots.bj)	QR en haut à droite, contrôle sans connexion depuis le portail	Idem ; ne couvre pas les contrats entre particuliers ou entreprises
Gestion électronique des courriers (GEC), Bénin	Numérisation du courrier entrant/sortant, indexation, suivi ; déployée par l'ASIN, ex. à la HAAC en juin 2026	Outil interne à l'administration ; pas de vérification par un tiers
SyGEC, Sénégal	Gestion électronique du courrier, 40+ structures publiques	Même logique logistique
Page de vérification DocuSeal / Yousign (voir section précédente)	Contrôle d'un PDF signé sur la plateforme	Uniquement du numérique natif

Ce que ça implique :

- **Le geste « scanner un QR pour vérifier » est déjà appris par les Béninois** grâce à l'ANIP. Verify peut s'appuyer sur ce réflexe sans éducation supplémentaire.
- **Trace comble un vide réel** : la GEC suit le courrier, pas la preuve. L'argument de soutenance est « dossier de preuve », pas « suivi logistique » — cohérent avec les décisions actées.
- **La GEC documente les freins terrain** : formation insuffisante, connexion internet instable, résistance au changement. Ce sont les mêmes risques pour SignSecure.

Afrique de l'Ouest et Bénin

Dans la région, la signature électronique avance surtout par l'État, pour l'État, avec des PKI nationales et des prestataires agréés. Le terrain des PME, associations et particuliers qui signent encore sur papier reste peu couvert.

Pays	Initiative	Ce qu'elle apporte	Leçon pour SignSecure
Bénin	eConseil, plateforme de dématérialisation du Conseil des ministres gérée par l'ASIN	Circuit de signature interne à l'État	Le marché public est déjà servi par l'ASIN ; viser le privé
Bénin	Gestion électronique des courriers (GEC), voir section précédente	Suivi du courrier administratif	Freins documentés : formation, réseau, résistance au papier
Bénin	ANIP : CIP et CNI avec QR vérifiable	Vérification publique sans compte	Le réflexe QR existe déjà
Côte d'Ivoire	Sygidan-Cti : signature des PV, délibérations, mandats et bons de commande des collectivités ; PKI nationale de l'ANSSI-CI en service depuis juillet 2026 ; objectif « zéro papier » 2030	Déploiement par vagues (104 élus en 2024, 232 collectivités visées)	Adoption lente, par l'accompagnement
Côte d'Ivoire	3 prestataires agréés par l'ARTCI : Cryptoneo, DKB Solutions, ITA (source : CIO Mag, page non consultable lors de la recherche)	Signature à certificat	La signature qualifiée passe par un prestataire agréé, jamais par un MVP
Burkina Faso	FasoSign, lancement annoncé en septembre 2026	Plateforme publique de signature	Même tendance : l'État d'abord

On n'a pas trouvé d'acteur privé béninois grand public comparable à Yousign. Point à vérifier sur le terrain (incubateurs Sèmè City, cabinets d'avocats, notaires) avant la soutenance.

Contexte béninois

Le Code du numérique (loi n° 2017-20) admet la preuve électronique et la signature simple, mais réserve la présomption de fiabilité à la signature qualifiée. SignSecure se situe donc en signature simple ou avancée : sa valeur repose sur la qualité du dossier de preuve, appréciée par le juge.

Cadre juridique utile au projet

Article	Ce qu'il dit	Conséquence pour SignSecure
Art. 266	L'acte électronique vaut l'acte papier si l'auteur est identifié et l'intégrité assurée ; nul ne peut être contraint au numérique	Garder un parcours papier : c'est la raison d'être de Trace
Art. 267	Exclus du format électronique : sûretés (hors usage professionnel), droit de la famille, successions	Afficher un avertissement à la création d'un document dans ces catégories
Art. 268	Preuve électronique recevable si l'auteur est identifiable et l'intégrité et la pérennité conservées	Justifie le hash serveur, le journal chaîné et la conservation
Art. 269	Conservation : dates et heures de création, envoi, réception, origine et destination	Horodatage serveur de chaque événement, déjà prévu
Art. 271	Copie électronique = même valeur si intégrité conservée ; certificat de conformité par un prestataire de confiance	Trace ne produit PAS de copie conforme ; il produit un dossier de preuve
Art. 284–285	Signature = identifie + manifeste le consentement ; fiabilité présumée seulement si qualifiée (certificat qualifié)	Case de consentement + OTP = consentement tracé ; pas de présomption
Art. 286	Signature avancée : liée au signataire, l'identifie, sous son contrôle exclusif, toute modification détectable	Le lien unique + OTP + hash couvrent la détection de modification ; l'identification reste déclarative
Art. 299–300	Un horodatage non qualifié reste recevable comme preuve	Horodatage serveur recevable, sans présomption

Article	Ce qu'il dit	Conséquence pour SignSecure
Art. 302	L'archivage s'applique aux documents numérisés comme aux documents natifs	Trace entre dans ce cadre
Art. 306 et 324	Le prestataire de confiance qualifié se déclare ; usurper cette qualité est puni de 3 à 6 mois et 500 000 à 10 000 000 F CFA	Ne jamais se présenter comme prestataire de confiance : règle déjà actée, ici avec base légale
Art. 405	Déclaration préalable à l'APDP de tout traitement de données personnelles	À mentionner comme prérequis d'une mise en production
Art. 407	Autorisation préalable de l'APDP pour : numéro national d'identification, biométrie, transfert vers un État tiers	Ne pas stocker le NPI ; pas de biométrie ; attention à l'hébergement hors Bénin
Art. 424 et 433	Protection dès la conception, minimisation, durée de conservation limitée	Conforte la règle « image de signature jamais stockée » et la page Verify minimale

Réalités terrain

- **Le mobile est le seul canal de masse.** 10,6 millions d'abonnements internet mobile actifs contre une pénétration de l'internet fixe inférieure à 1 % au 30 septembre 2025 (ARCEP, observatoire T3 2025). Le parcours de signature doit être pensé d'abord pour un téléphone.
- **Les femmes ne pèsent que 22 % des abonnements internet mobile actifs** (même source). Un signataire peut ne pas avoir d'email : l'OTP SMS doit rester possible.
- **Mobile Money interconnecté** : MTN MoMo, Moov Money et Celtiis Cash fonctionnent sur tous les réseaux depuis janvier 2025 (ARCEP). Utile pour un futur modèle de paiement à l'acte, hors MVP.
- **Connexion instable et formation insuffisante** : freins cités pour la GEC. Prévoir des PDF légers, une reprise possible du parcours, des messages courts en français clair.
- **Culture du cachet et du papier** : le document physique signé et tamponné reste la norme dans les PME. Trace répond à cette réalité plutôt que de la nier.
- **Administration sans papier** : une circulaire conjointe du 24 juillet 2026 lance la réforme dans les ministères et collectivités (source : Capmad, page non consultable lors de la recherche). Le sujet est d'actualité pour la soutenance.

Matrice comparative

SignSecure est la seule solution du panel à couvrir Sign, Verify et Trace ensemble. Ses deux écarts concrets avec le marché sont l'absence d'OTP par SMS et une comparaison de photo encore simulée.

Fonctionnalité	DocuSign	Yousign	Documenso	DocuSeal	ANIP / e-services	GEC Bénin	SignSecure (code actuel)
Lien de signature par email	Oui	Oui	Oui	Oui	—	—	Oui, unique, 48 h
OTP SMS	Oui	Oui	Non documenté	Pro	—	—	**Non** (email seul, `otpProvider.ts`)
OTP email	Oui	Oui	Non documenté	Non documenté	—	—	Oui
Consentement daté séparément	Oui	Oui	Non documenté	Non documenté	—	—	Oui (`consentedAt` + IP)
Vérification d'identité par pièce / biométrie	Oui	Oui (avancée)	Non	Non	—	—	Exclu (décision actée)
Signature qualifiée	Oui (UE)	Oui (UE)	Non	Non	—	—	Exclu
Dossier / rapport de preuve	Certificate of Completion	Audit trail par signataire	Audit log	Non documenté	—	—	Oui (ProofReport)
Journal d'audit chaîné par hash	Non documenté	Non documenté	Non	Non	—	—	Oui
Vérification publique sans compte	Non (via admin)	Par hash	Non	Oui	Oui (QR)	Non	Oui (code + QR)
Prise en charge du papier signé	Non	Non	Non	Non	Non	Suivi courrier	Oui (Trace)
Comparaison photo / scan	Non	Non	Non	Non	Non	Non	**Simulée** (taille de fichier)
Auto-hébergeable	Non	Non	Oui	Oui	—	—	Oui

« Non documenté » = absent des pages consultées, pas forcément absent du produit.

Deux constats de code à traiter avant la soutenance :

- **Comparaison Trace (`backend/src/modules/verify/service.ts`)** : le score est calculé sur la taille des fichiers, pas sur le texte. Le commentaire le dit honnêtement, mais un jury peut le relever.
- **Même fichier** : l'origine Trace renvoie aussi `resultat: correspond / diverge` (seuil 80). C'est un verdict binaire, alors que CLAUDE.md impose d'afficher uniquement un score pour les documents Trace. À vérifier côté front (`FileComparison.tsx`).

Ce qu'on peut reproduire dans le MVP

Sept emprunts sont compatibles avec CLAUDE.md et réalisables avant la soutenance ; les trois premiers ont le meilleur rapport impact / effort.

Priorité	À reproduire	Inspiré de	Pourquoi au Bénin	Effort estimé
1	OTP par SMS, via un nouveau `OtpProvider` (mode sandbox clairement étiqueté si pas d'agrégateur)	DocuSign, Yousign	Mobile = canal de masse ; beaucoup de signataires sans email actif	Faible : l'interface existe déjà
2	Rapport de preuve structuré en 5 blocs : expéditeur, signataire, mode d'authentification, contexte et dates (consentement puis validation), empreinte SHA-256	Yousign	Art. 268 : la valeur tient à l'identification et à l'intégrité démontrées	Faible : données déjà en base
3	Remplacer la comparaison par taille de fichier. Option A : affichage côte à côte, jugement humain enregistré. Option B : OCR (ex. tesseract.js), **à valider avant** car CLAUDE.md impose une confirmation	— (aucun concurrent ne le fait)	C'est le cœur différenciant de Trace	A : faible ; B : moyen
4	QR + code de suivi imprimés dans le pied de page du PDF signé	ANIP, e-services	Geste déjà connu des Béninois	Faible (à vérifier : peut-être déjà fait)
5	Avertissement à la création pour les actes exclus du numérique (sûretés, famille, successions)	—	Art. 267 du Code du numérique	Faible

Priorité	À reproduire	Inspiré de	Pourquoi au Bénin	Effort estimé
6	Relance automatique du signataire avant expiration du lien de 48 h	DocuSeal Pro, DocuSign	Réseau instable, emails lus tard	Faible
7	Page « Données personnelles » : finalités, durées, mention de la déclaration APDP nécessaire en production	—	Art. 405, 415, 433	Faible

Ce qu'on écarte, et pourquoi

Écarté	Présent chez	Raison
Vérification d'identité par pièce, selfie, biométrie	DocuSign, Yousign	Exclu par décision actée ; autorisation APDP requise (art. 407)
Signature qualifiée, certificats	DocuSign, Yousign, prestataires ivoiriens	Réservée à un prestataire qualifié ; s'en prévaloir est un délit (art. 324)
Stockage ou usage du NPI	Services ANIP	Autorisation APDP requise (art. 407)
Paiement Mobile Money	—	Hors MVP ; bonne piste de modèle économique à citer
OTP par WhatsApp	—	Canal très utilisé mais dépend d'une API tierce payante ; non acté — à citer comme piste
Blockchain, IA de détection de fraude	Divers	Exclus par CLAUDE.md ; le journal chaîné couvre la détection de falsification

Sécurité : SignSecure face aux solutions existantes

Sur les comptes internes, SignSecure est au niveau du marché. Le vrai écart est ailleurs : le PDF signé n'est pas scellé cryptographiquement. Son intégrité ne se contrôle donc qu'en passant par SignSecure. Tous les concurrents étudiés scellent le PDF.

Mesure	Solutions existantes	SignSecure (code vérifié)	Écart
Scellement du PDF final	DocuSign : sceau PKI « tamper-evident » ; Documenso : certificat X.509 obligatoire	Hash SHA-256 calculé côté serveur et stocké en base ; PDF non signé numériquement (`sign/pdf.ts`)	**Majeur** : un lecteur PDF (Acrobat) ne détecte aucune modification
Horodatage	Serveur d'horodatage tiers (RFC 3161) en option chez Documenso	Horloge du serveur SignSecure	Moyen : recevable (art. 299), mais contrôlé par l'opérateur
Canal de l'OTP de signature	SMS ou appel, distinct de l'email du lien	Email, **la même boîte** que celle qui reçoit le lien (`sign/service.ts`)	**Majeur** : une boîte mail piratée suffit pour signer à la place de quelqu'un
Lien de signature	Lien unique par destinataire	Aléatoire (UUID), usage unique, 48 h	Aucun
Force brute OTP	Limitée	5 essais, puis délai de renvoi	Aucun
Comptes internes	2FA, SSO en offre entreprise	Mot de passe bcrypt + OTP, verrouillage après 5 échecs pendant 15 min, audité	Aucun pour un MVP
Expiration après inactivité	Standard	Jeton de 2 h, **aucune expiration sur inactivité trouvée**	Faible, mais exigé par CLAUDE.md
Journal d'audit	Stockage « tamper-evident », certificat de fin	Journal chaîné par hash + contrôle d'intégrité (`verifyAuditChain`)	Moyen : quelqu'un qui peut écrire en base peut recalculer toute la chaîne

Mesure	Solutions existantes	SignSecure (code vérifié)	Écart
Chiffrement des fichiers au repos	AES-256 chez DocuSign	Fichiers en clair sur disque, servis seulement via endpoint autorisé	Faible pour un MVP
Code public de vérification	—	8 caractères aléatoires, 60 requêtes / 15 min, réponse `UNKNOWN_CODE` neutre	Aucun
Certifications (ISO 27001, SOC 2)	DocuSign	Aucune	Hors périmètre d'un MVP

Scénarios de fraude

Sur 15 scénarios, 6 sont couverts, 5 le sont partiellement et 4 ne le sont pas. Les trous les plus graves concernent l'identité du signataire et la confiance accordée à un QR imprimé.

Non couverts

Scénario	Exemple concret	Parade réaliste en MVP
Boîte mail du signataire piratée	Le fraudeur reçoit le lien ET l'OTP dans la même boîte, et signe	OTP par SMS sur un numéro distinct (priorité 1 de la section précédente)
Faux signataire saisi par l'émetteur	L'émetteur indique comme « signataire » une adresse et un numéro qu'il contrôle	Refuser un signataire dont l'email ou le téléphone est celui de l'émetteur ; écrire dans le rapport « identité déclarée par l'émetteur, non vérifiée »
QR piégé ou faux site de vérification	Un faux document porte un QR vers un site imitant Verify, qui affiche « signé »	Imprimer en clair sous le QR le domaine officiel et le code saisissable à la main ; sensibiliser sur la page Verify
Photo Trace falsifiée ou ancienne	L'agent importe depuis la galerie une photo retouchée ou prise avant la réception	Autoriser uniquement la capture caméra (l'import galerie existe dans `CameraCapture.tsx`) ; calculer côté serveur le hash de chaque photo à l'envoi et l'inscrire au journal

Partiellement couverts

Scénario	Ce qui existe	Ce qui manque
PDF modifié puis imprimé avec le vrai QR	Le hash détecte la modification si le fichier est soumis à Verify	Qui scanne seulement le QR voit « signé » sans comparer le contenu. Imprimer les 8 premiers caractères du hash et le nombre de pages ; inviter à soumettre le fichier
Répudiation (« ce n'est pas moi qui ai signé »)	Consentement daté, IP, OTP consommé, journal chaîné	Canal distinct (SMS), navigateur / appareil (user-agent) non enregistré

Scénario	Ce qui existe	Ce qui manque
Administrateur ou personne ayant accès à la base qui réécrit l'historique	Journal chaîné + contrôle d'intégrité	Ancrage externe : envoyer chaque jour le dernier hash du journal par email au superviseur, ou le faire horodater par un tiers
Pages remplacées sur l'original papier après enregistrement Trace	Photos de référence + nombre de pages déclaré	Photo obligatoire de chaque page ; vraie comparaison au lieu du score par taille de fichier
SIM swap (si l'OTP SMS est ajouté)	—	Fraude signalée au Bénin ; exiger SMS + email pour les documents sensibles et le documenter comme limite

Couverts

- Rejeu ou partage du lien de signature : usage unique, 48 h, OTP requis.
- Force brute sur l'OTP : 5 essais maximum.
- Énumération des codes de suivi : codes aléatoires, limitation du débit, réponse neutre.
- Force brute sur les comptes internes : verrouillage après 5 échecs, audité.
- Accès aux fichiers d'une autre organisation : aucun accès direct, contrôle `organization_id` serveur.
- Hash du document falsifié par le client : toujours calculé côté serveur.

Hors portée pour tous, concurrents compris : signature sous contrainte, ou par un proche qui a le téléphone déverrouillé. Et Trace prouve qu'un document a été déclaré reçu à une date donnée, pas que son contenu est authentique : à dire clairement au jury.

PKI : indispensable ou pas ?

Une PKI n'est indispensable que pour la signature qualifiée, exclue du MVP. En revanche, un cachet serveur fondé sur une paire de clés est la pratique de tout le marché. C'est le meilleur moyen de combler l'écart « PDF non scellé ».

Ce que c'est. Une PKI (infrastructure à clés publiques) associe une clé privée secrète à un certificat public délivré par une autorité de certification. Signer un PDF avec la clé privée y intègre une signature numérique (format PAdES). N'importe quel lecteur PDF détecte alors toute modification, sans interroger SignSecure.

Trois niveaux à ne pas confondre :

Niveau	Qui détient la clé	Ce que ça apporte	Pour SignSecure
Certificat qualifié par signataire	Chaque signataire, via un prestataire de confiance qualifié	Présomption de fiabilité (art. 284–285)	**Exclu** : exige un prestataire qualifié ; s'en prévaloir sans l'être est un délit (art. 324)
Cachet de plateforme avec certificat d'une autorité reconnue	La plateforme (ex. DocuSign)	Coche verte dans Acrobat, détection de modification	Hors MVP : exige une vraie autorité de certification
Cachet de plateforme auto-signé	SignSecure, clé générée localement	Détection de modification dans tout lecteur PDF ; Acrobat affiche « validité inconnue », comme l'explique Documenso	**Faisable**, à étiqueter « cachet de démonstration, non qualifié »

Le Code du numérique reconnaît ce dernier cas : un cachet électronique non qualifié reste recevable, seule la présomption d'intégrité lui manque (art. 293).

Recommandation pour le MVP, du plus simple au plus complet :

1. Imprimer sur le PDF final le code de suivi, le QR et le début du hash. Effort faible, aucune clé à gérer.
2. Ajouter un cachet de plateforme auto-signé (PAdES) sur le PDF final, après l'incrustation de la signature et avant le calcul du hash. Effort moyen : nouvelle dépendance de signature PDF, clé privée hors dépôt git.
3. Optionnel : faire horodater ce cachet par un serveur d'horodatage tiers (RFC 3161). Seul le hash sort, aucune donnée personnelle. À valider, car c'est un service externe.

À dire au jury : « SignSecure scelle ses documents avec sa propre clé pour rendre toute modification détectable. Il ne délivre pas de certificat aux signataires et n'est pas un prestataire de confiance. »

Positionnement pour la soutenance et prochaines étapes

Message central : « Les solutions existantes signent du numérique ou suivent du courrier. SignSecure relie les deux et produit un dossier de preuve vérifiable par un tiers, sans prétendre être un prestataire de confiance. »

Arguments à défendre :

- **Adapté au papier** : au Bénin, le document signé à la main reste la norme ; nul ne peut être contraint au numérique (art. 266).
- **Honnête sur sa valeur juridique** : signature simple ou avancée, dossier de preuve apprécié par le juge (art. 268), jamais de présomption revendiquée (art. 284).
- **Protection des données dès la conception** : image de signature jamais stockée, page Verify minimale, pas de biométrie ni de NPI (art. 407, 424).
- **Vérification publique** : absente des open source étudiés, familière aux Béninois grâce à l'ANIP.
- **Journal d'audit chaîné** : détection d'altération sans blockchain.

Questions probables du jury, à préparer :

- « Quelle valeur devant un tribunal béninois ? » → art. 266, 268, 284–286.
- « Pourquoi pas DocuSign ? » → coût, pas de papier, hébergement hors Bénin (transfert vers un État tiers soumis à autorisation, art. 407).
- « Comment comparez-vous une photo ? » → dépend du choix fait en priorité 3.

Prochaines étapes :

- [ ] Trancher l'option A ou B pour la comparaison Trace
- [ ] Corriger le verdict binaire renvoyé pour les documents Trace
- [ ] Ajouter l'OTP SMS (sandbox) via `OtpProvider`
- [ ] Restructurer le rapport de preuve en 5 blocs
- [ ] Vérifier si le QR est imprimé dans le PDF signé
- [ ] Confirmer sur le terrain l'absence d'acteur privé béninois comparable
- [ ] Revérifier les pages non consultables (Capmad, CIO Mag, Lextenso)

Côté sécurité :

- [ ] Envoyer l'OTP de signature par un canal distinct du lien (SMS)
- [ ] Refuser un signataire dont l'email ou le téléphone est celui de l'émetteur
- [ ] Imprimer sur le PDF le domaine officiel, le code, le QR et le début du hash
- [ ] Trace : capture caméra uniquement et hash de chaque photo à l'envoi
- [ ] Expiration de session après inactivité
- [ ] Enregistrer le navigateur / appareil (user-agent) à la signature

- [ ] Ancrer chaque jour le dernier hash du journal d'audit (email au superviseur)
- [ ] Décider du cachet PDF auto-signé et de l'horodatage tiers

Sources

Pages consultées le 28 septembre 2026 :

- Code du numérique du Bénin, loi n° 2017-20 (PDF, AFAPDP)
- Décryptage du Code du numérique, Village de la Justice
- Yousign / Youtrust : contenu de l'audit trail
- DocuSign Phone Authentication
- Documenso Docs et demande de vérification publique (issue #1764)
- DocuSeal sur GitHub
- ANIP : Certificat d'Identification Personnelle et En ligne au Bénin : vérification du CIP
- La Nation : plateforme GEC
- Notre Époque : l'ASIN forme la HAAC à la GEC
- OSIRIS : signature électronique des collectivités ivoiriennes
- Digital Business Africa : FasoSign
- ARCEP Bénin : observatoire internet T3 2025 (PDF) et interconnexion Mobile Money

Ajoutées pour les sections sécurité, fraude et PKI :

- DocuSign : Is your eSignature safe?
- Documenso : certificat de signature
- Financial Afrik : la fraude par échange de carte SIM en Afrique

Citées d'après un résultat de recherche, page non consultable : CIO Mag, prestataires agréés en Côte d'Ivoire, Capmad, administration sans papier, CatIS, eConseil.